VPN

Monday, August 18, 2025 2:01 PM

VPN :

- **What is VPN ?**
  - Is a technology that creates a secure , encrypted connection or tunnel over less secure network like the internet
  - Tunnel does not make security, it is just a virtual path. It's not secure we have to secure using IP sec.
  - **Underlay** :This is the physical infra responsible for reachability.
  - **Overlay** : Virtual Network built on top of the Underlay (Physical Infra). Encapsulating the traffic.

Definition VPN :
Over a public network I want to communicate between two private network through secure tunnel.

What can VPN do ?
VPN can securely carry your data from source to destination.

Where do we need a VPN ?
Need a VPN to communicate between private network and public network.

Why do we need VPN?
Because the internet was not secure by default. A VPN gives security, privacy, and accessibility that a normal connection can't provide.

Securely transfer your data from one place to another place

- **What is the CIA ?** imp
  - C = Confidentiality (data is private)
  - I = Integrity (Trust)
  - A = Availability (data/services are accessible when needed)

- Why encryption is important?
  - For CIA

- **Categories of VPN :**
  i. **Routing Based VPN :** Here routing decide what packet will go through the VPN tunnel. Preferred for scalable, flexible VPN design. Eg. GRE Tunnel (Generic Routing Encapsulation), DMVPN.
  ii. **Policy Based VPN :** Here ACL decides what packet will go through the VPN. Simpler to configure but less scalable. Preferred when routing protocols are not needed.
  iii. **Layer 2 VPNs :** Frame relay, L2TP V2, MPLS (Multiprotocol label switching)
- **Types of VPN:**
  i. **Site to Site VPN :**
     - A site-to-Site VPN connects to entire networks
     - Secure tunnel established between two or more branch /office networks.
     - Typically used by businesses to connect HQ to remote offices.
     - Traffic between sites is encrypted and authenticated.
  ii. **Remote Access VPN :**
     → Allows individual users to securely connect to a central private network.
     → Ideal for remote worker or travelers.
     → Uses client software (**Open VPN** (It is open source and it mostly used in a small enterprises, Highly configurable, less cost), **Any Connect** (Its Cisco proprietary. Design for large enterprises. Its costly and easy for users)).
     → Provides access to internal resources as if locally connected.
     → Client-less VPN is also known as web VPN or SSL VPN

- **Different type of keys** :
  i. **Symmetric Key** - Same key used for **encryption + decryption**.
  ii. **Asymmetric Key** - a key pair generated,
     - Involves using two different keys "**private" & "public**". Message encrypted with one decrypted with another from the pair.
       - **Public key** (also called encryption key).
       - **Private key** (also called decryption key)
  iii. **HMAC Key-**
     - Used for message integrity and authentication .
  iv. **PKI (Public key Infrastructure) :**
     - PKI is the architect used to manage digital identities through certificates..
     - **Digital Signature Keys:**
       ✓ Used to confirm identity and integrity.
       ✓ **Types:**
         ◇ **Signing Key (Private)**
         Used to generate digital signatures.
         ◇ **Verification Key (Public)**
         Used to verify the signature.

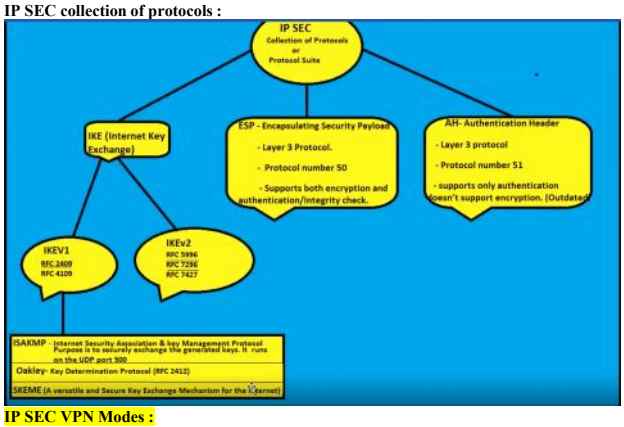
- **Cryptographic Method**
  - **Encryption :** Makes the original message unreadable for unknown parties.
  - **Encryption can be :**
    - What is asymmetric key?
      - It generate a pair of keys Uses two different keys:
      ✓ **Public Key** → used for encryption
      ✓ **Private Key** → used for decryption
    - What is symmetric Key?
      ✓ A single *same* key is used for **encryption** and **decryption**.
  - **Symmetric Encryption Algorithms :**
    - DES (Data Encryption Standard) (56 Bit key)
    - 3 DES (Effectively triples encryption strength over DES)
    - AES (Advanced Encryption Standard 128,192,256)
  - **Asymmetric Encryption Algorithms :**
    - RSA {Rivest Shamir Adleman} is a public-key cryptosystem for internet encryption and authentication .(512, 768, 1024 or larger keys can be used)
    - DSA (Digital Signature Algorithm)
    - DH (Diffie- Hellman) :
      ✓ DH Group 1 : 768- bit group
      ✓ DH Group 2 : 1024- bit group
      ✓ DH Group 5 : 1536-bit group
      ✓ DH Group 14 : 2048- bit group
      ✓ DH Group 15 : 3072 - bit group
      ✓ DH Group 19 : 256- bit elliptic curve group

Interview Questions :
Differences:

1. Policy Based VPN & Router based VPN?
2. IKEv1 & v2?
3. GRE, MGRE, DMVPN.
4. Messages
5. Diffie Hellman group ?
6. SSL Handshake ?
7. Diff bw SSL & TLS.
8. Client full VPN ?
9. Client less VPN?
10. Difference between symmetric and asymmetric?
11. What is CIA?

- ✓ DH Group 20 : 384-bit elliptic curve group
  - **What is Diffie Hellman ?**
    - **Diffie-Hellman** is a mathematical method that used to securely exchange **encryption keys** over a public, insecure network
  - Why do we use it ?
    - Safety over public Wi-Fi
    - Perfect forward secrecy
    - No prior meeting needed
  - **What is PFS & DH?**
    - **Perfect Forward Secrecy** for keys, identity protection and authentication.
- **HASH (Data Integrity)**
  - → Detects any modification of the original message Implemented with the aid of hashing functions
  - → It is a one way process and cannot reverse it.
    - MD5 products 128-bit hashes (out dates)
      - **Messaged Digest (One-way Hash) Functions (MD5):**
        - ✓ Hash function calculation a unique fixed-size bit string representation called message digest of any arbitrary block of information.
    - SHA-1 (Secure Hash Standard) products 160-bit hashes. (We use minimum)
    - SHA-2 variation (256,384,512- output sizes)
- **HMAC (Hashed Message Authentication Code): (it will be used phase 2)**
  - → Includes a shared key when calculating a hash
  - → Provides integrity and data authentication
  - → Examples are HMAC-MD5 and HMAC-sha 1.

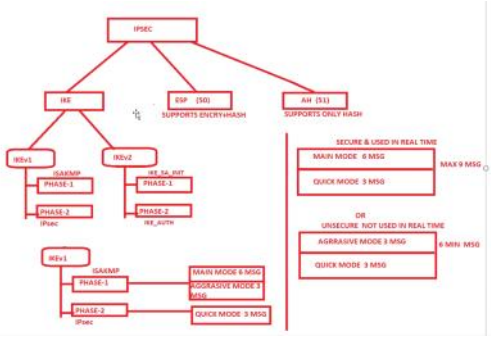
- **IP sec {Internet Protocol Security}:**
  - A suite of protocols used to secure data transmitted over an IP network. It is the engine behind most VPNs.
  - IP sec is a framework of protocols and open standard. The main objective of IP sec is to provide a set of cryptographic method to protect IP packets at layer 3
  - Most common implementation of VPNs at Layer 3 (secure implementation)
  - A protocol specifically designed to provide **integrity and authentication** for IP packets.
  - IP sec is not a single protocol rather it is a suite of protocols used to provide these services.
    - These protection services include : CIA
      - → Confidentiality (encryption)
      - → Integrity/ HASH
      - → Availability
      - → Authentication
      - → Replay Protection
  - **In which scenarios IP sec will use ?**
    - IPsec is used wherever we need secure, encrypted, and authenticated communication over an untrusted network, especially internet-based VPNs.
    - Site to site VPN, Remote based VPN, Encrypting traffic between routers/firewalls(OSPF + IP sec), Securing communication between Data centers, Cloud connectivity
  - **IP Sec uses two different packet headers to deliver the security services :**
    - **Authentication Header :**
      - → **Protocol Number 51**
      - → Supports only authentication
      - → Doesn't support encryption
    - **Encapsulating Security Payload (ESP) :**
      - → Layer 3 Protocol
      - → **Protocol Number 50**
      - → Supports both encryption and authentication/integrity check.
    - **What is the difference between AH and ESP.?**

- **IP SEC collection of protocols :**
- 

- **IP SEC VPN Modes :**
  - **Tunnel Mode =**
    - Default VPN Tunnel mode in VPN when you configure IP Sec. generally used in site to site VPN.
    - How it work : Encrypts the entire original packet and adds a new set of IPsec headers. These new header are used to route the packet and also provide overlay function.
  - **Transport Mode** =
    - used for host to host encryption or when another tunneling protocol is already doing the encapsulation.
    - How it work - IP sec encrypts only the payload. The original IP header is kept visible and is used to route the packet across the internet.

Q. What are the modes of IP Sec ?

- What is difference between Tunnel mode and Transport Mode?

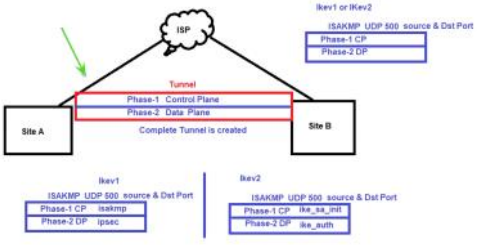
- 

- **IKE (Internet Key Exchange) :**
  - Internet key exchange is a protocol that perform authentication between two end-points to establish security associations, also known as IKE tunnels. These security associations, or tunnels, are used to carry control plane traffic for IP sec.
  - There are two versions IKEv1 and IKEv2.
  - **IKE v1 :**
    - Internet Security Association Key Management Protocol (ISAKMP) is frame work for authentication and key exchange between two peers to establish, modify, and tear down SA's.
    - **What is PFS?** (Perfect Forward Secrecy for keys, identity protection and authentication. It is used in phase 2)
    - Phase 1 tunnel is life time is 24 hours and Phase 2 tunnel is 1 hour.
    - Phase 1 is represent the control plane (it established a secure management channel so routers can safely talk use port no. 500) and Phase 2 is for data plane (traffic generated by users. It flows inside the tunnel created by the control Plane.)
    - **ISAKMP defines two phases :**

→

Phase 1	Phase 2
→ Used for control plane	→ Used for data Plane
→ Establish secure channel between peers	→ Transports the protected data
→ Prove identities	
→ Negotiate data plane security settings	
Modes : Main Mode and aggressive mode	Quick Mode

    - Phase 1:
      - **Main Mode**
        - 6 packets exchange.
        - Full identity protection (protects against passive surveillance)
        - Better Anti-Dos protection
      - **Aggressive Mode :**
        - 3 packet exchange
        - Identification passed in the clear
        - Responder must authenticate himself first
        - PSK can be retrieved by an offline brute-force attack
        - Trivial to DOS
        - Faster session establishment.
    - Phase 2
      - **Quik Mode :**
        - 3 messages exchange
        - Traffic to be protected
        - How to be encapsulated
        - How to be encrypted
        - How to be Provide integrity
        - How long the SA is valid for in time and volume of data
        - If perfect forward secrecy (PFS) is required.

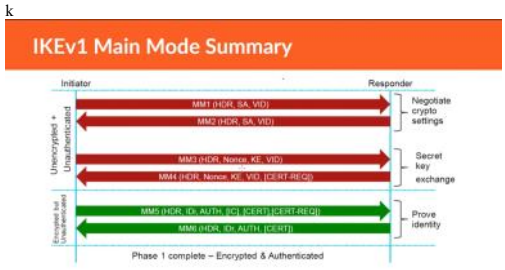
- 

    - **Phase 1 (ISAKMP)** : main mode 6 msg (initiator send msg and responder give reply), aggressive mode 3 msg
      → Default mode is main mode.

→ **Main Mode** (message 1&2)
- The first two messages are used to negotiate the following cryptographic attributes:
  - Integrity **H**ash
  - **A**uthentication method
  - Diffie-Hellman Key Exchange **G**roup
  - **L**ifetime of Security Association
  - **E**ncryption cipher
- Initiator Proposes a list of combinations of the starred ()

Initiator	Responder
1st msg : First we have Security Association (SA) under that we have Proposal payload under that we have transform Payload under that we have HAGLE. ◆ Three thing comes under the first message exchange 1. SPI (Security Parameters Index) : It's a unique number create per session or security purpose. 2. HAGLE 3. Vendor ID payload : it shows the support of NAT-T.	**Message 2** : "I accept." ◆ The responder selects one of the proposals sent in Msg 1 that matches its own configuration. ◆ Contains the Responder SPI (Cookie)
→ **3rd message :** key generated by DH. Key exchange payload and Nonce payload (it attached with key exchange payload). ◆ 2 NAT-D payload. ◆ NAT- D stands for Nat discovery. ◆ Peer NOT authenticated yet. In this message hashed value will not matched. Because of translation device it there.	**Message 4 :** Here is mine." ◆ Sends its own **KE** payload (Diffie-Hellman public key) and **Nonce**. ◆ At this point, both sides calculate the shared secret key (SKEYID). Encryption begins after this step.
→ If the hash values in message 3 and 4 are not matching on initiator and Responder side, this means there is a NAT device present between the peers.	**→ If translation device is detected then the initiator and responder will switch the traffic to UDP port 4500 instead of UDP 500.** **→ UDP port will work from 5th and 6th message.**
5th message : ◆ It contains Identification payload and Hash Payload. Used for identification and authentication. ◆ Both messages are encrypted.	**Message 6 :** "Here is my ID (Encrypted)." ◆ Sends its **ID** and **Hash**. ◆ *Note: This message is encrypted.* ◆ **Result:** The Phase 1 Tunnel (ISAKMP SA) is now up.

→ k

→ 

A. Do proper research on 3rd 4th and 5th message exchange ?

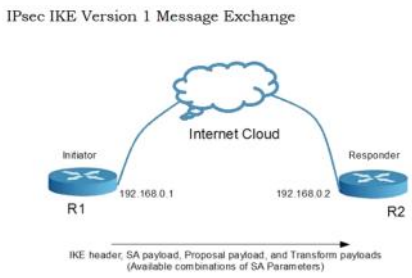
Q. What is nonce payload and use of that ? It is unique numeric number and It's used to preventing Replay attack.

Q. What is replay protection ?
   i. "**Anti-Replay Protection** uses **Sequence Numbers**, for that we have a Nonce Payload that we're exchanged in message 3rd and 4th.

Q. From which message exchange UDP Port no. 4500 will starts ? Ans. 5th and 6th.

R. What is NAT-T and NAT-D and Vender ID payload ? Vender ID payload = It allows peers to advertise which features or drafts they support., NAT- D= NAT Discovery Payload = Is there a NAT router between us?" NAT-T = Translating device used between the tunnel.

S. When hast get change in NAT D?
   → The hash value changes (mismatches) when a NAT device in the path modifies the Source IP, Destination IP, or Port number of the packet.

→ 

→ Initiator Security Parameter Index (SPI) : it's a unique number generated per session.
→ Hagle :
→ Vender ID Payload : It have fixed Hash values.

→

INTIATOR	RESPONDER
1st SPI, HAGLE, V-ID	2nd SPI, HAGLE, V-ID
3rd Key Payload, Nonce, NAT-D	4th KEY, NONCE, NAT-D Payload
5th Identity Payload(in that ID) Encrypted Hash Payload	6th Identity Payload Encrypted.

Q. What is pseudo random function?

> the **Pseudo-Random Function (PRF)** is used primarily during the initial handshake (Phase 1) to transform secret data into the actual encryption keys used for secure communication.

- **Phase 2 (IP sec)**: **Quick mode 3 msg**
  - Main Mode and Quick mode all information carries under ISAKMP. Its work with **UDP Port 500** for source and destination.
  - Traffic to be protected
  - How to be encapsulated
  - How to provide integrity

  → Initiator send a packet that includes SA, Nonce, Proposed traffic Selectors, NAT address information.
  → **1st msg** - Request
  → **2nd MSG-** YES or NO
  → **3rd MSG** - ACK

- **Aggressive Mode (Phase 1) :**
  - In aggressive mode have a 3 messages.
  - The first two messages in Aggressive mode exchange include almost everything required to from IKE SA.
  - IKEv1 phase 1 aggressive mode is quicker than Main Mode , but endpoint identities are exchange in Clear-Text.
  - Main mode is more secure than Aggressive Mode, because the identification payload is encrypted in main mode.
  - **IKEv1 Phase 1 Aggressive Mode Message 1:**
    - All the necessary information required to generate the Diffie-Hellan shared secret is exchanged in the first two messages between peers.
    - The first message sent from the information includes SA payload, Proposal payload, Transform payload like Main Mode.
    - Its contains Diffie-Hellman Key Exchange payload and the Nonce Payload.
    - Identification payload is also added in the first message and it is in Clear-Text, not encrypted.

  - **IKEv1 Phase 1 Aggressive Mode - Message 2 :**
    - The responder can generate the Diffie-Hellman shared. The Responder generates the Diffie-Hellman shared secret. Responder generates the Hash also for Authentication purpose. Similar to message 2 in IKEv1 Phase 1 main mode.
    - Contains the agreed proposal and transform pair from the responder.
    - Contain Key Exchange Payload, Nonce Payload, Identity Payload and Authentication Hash from the Responder.

  ➢ **Aggressive Mode (3 Messages):**
  Faster, but sends the ID in clear text (less secure). Often used for Remote Access VPNs.
  → **Message 1 (Initiator → Responder):** Sends SA **Proposal + Key Exchange + Nonce + ID**. (All in one go).
  → **Message 2 (Responder → Initiator):** Sends **Accept, SA Proposal + Key Exchange + Nonce + ID + Hash**.
  → **Message 3 (Initiator → Responder):** Sends its own authentication **Hash** (ACK). Authentication is complete in this message.

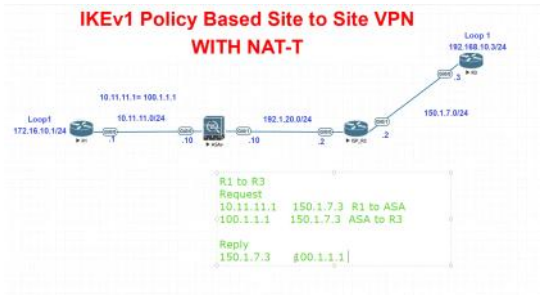
Q. What are IP Sec modes ? Tunnel Mode and Transport Mode.
Q. Tunnel and transport mode comes under which phase ? Phase 2

R.

- IKE v1- KEYS
  - From the derived secret value a SKEYID is created using values from the ISAKMP exchange.
  - Provides protection against replay attacks using the same DH values.
  - Different SKEYID generation based on authentication type.
    → Pre-shared -key : SKEYID = prf (Pre-shared -key)
    → Signatures (Certs): SKEYID = prf
  - Then from that SKEYID three sub-keys are created
    → SKEYID_d = prf - For further keying material derivation.
    → SKEYID_a = Authentication Key
    → SKEYID_e = Encryption Key.
- IKEv1 -Main Mode :
  - HDR
    → Cookie
      - Initiator = X (retained)
      - Responder = Y (Randomly generates per session)
    → SA (the selected crypto policy)
    → Vendor IDs- String or hash value. Used to advertise support for capabilities not in standard

Feature	IKEv1	IKEv2 (Current Standard)
Exchange Process	**Complex** (Two separate Phases: Phase 1 establishes the IKE SA, Phase 2 establishes the IPsec SA).	**Streamlined** (Combines both phases into two main exchanges).
Minimum Messages	**9 messages** (Main Mode + Quick Mode) or **6 messages** (Aggressive Mode + Quick Mode).	**4 messages** (IKE_SA_INIT + IKE_AUTH) to establish the IKE SA and the first Child SA.
Authentication Modes	Two distinct modes: **Main Mode** (secure, slower) and **Aggressive Mode** (faster, less secure as identity is exposed).	**One unified process** that is both fast and securely protects identity by default.
Authentication Methods	Limited. Relied on vendor-specific extensions (like XAuth) for user authentication.	**Native EAP** (Extensible Authentication Protocol) support, allowing for modern authentication methods (certificates, username/password).
NAT Traversal (NAT-T)	Implemented as an **optional extension** (required complex configuration).	**Built-in support** by default, improving reliability through firewalls and NAT devices.
Mobility	**Not supported** natively.	**Supported via MOBIKE** (Mobility and Multihoming Protocol) extension, allowing the VPN tunnel to stay up when the client's IP address changes (e.g., switching from Wi-Fi to cellular).
Reliability	No native mechanism for dead peer detection or handling retransmissions.	**Built-in DPD** (Dead Peer Detection) and robust sequence/request-response messaging improve stability.
SA Terminology	**IKE SA** (Phase 1) and **IPsec SA** (Phase 2).	**IKE SA** (Management Tunnel) and **Child SA** (Data Tunnel).

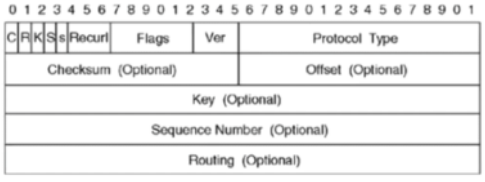
Feature	**IKEv1 (Legacy)**	**IKEv2 (Modern Standard)**
Speed	Slower (6–9 messages to start)	Faster (4 messages to start)
Phases	Two distinct phases (Phase 1 & 2)	Simplified "Exchanges"
Modes	Main Mode, Aggressive Mode, Quick Mode	Single Mode (Combines features)
Reliability	No built-in reliability (relies on timeouts)	Built-in (Sequence #s & Acks)
Mobility	Poor (Connection drops if IP changes)	MOBIKE (Survives IP changes)
NAT Traversal	Add-on (often buggy/incompatible)	Native / Built-in
Authentication	Symmetric (Must match on both sides)	Asymmetric (EAP support)

- **Site to Site VPN :**
  - **IKEv1 Policy Based Site to Site VPN**
    - ASA firewall should be enabled with NAT-T feature.
    - Cisco firewall by default allows NAT-T but when it's come to FortiGate, Palo Alto, checkpoint we need to enabled.
    - 

    -
    - Why need don't put Public IP direct because we need 2 different subnet public IP's. There is a waste of public IP's
    - In this topology tunnel was formed between R1 and R3.
    - On R1 I will give default route, so packet will goes to the ASA.
    - From ASA it will goes to ISP, from their it reached to the destination R3.

- **Route-Based VPN :**
  - Uses virtual tunnel interface (VTI).
  - Routing decides what traffic goes through the tunnel
  - Supports dynamic routing protocols
  - Preferred for scalable, flexible VPN design.

- **GRE Route based VPN :**
  - A tunneling protocol developed by Cisco.
  - Used to encapsulate a wide variety of Layer 3 Protocol over an IP network.
  - Provides a way to create point-to-point links between remote networks over the internet.
  - Protocol Number 47
  - Can encapsulate protocols like Ipv4, IPv6, IPX, Apple Talk
  - Commonly used in VPNs, site to site tunnels
  - No encryption or authentication.
    - GRE Header

→ 

→ 4 Bytes
→ Flags (C, R, K, S) : Optional fields (checksum, routing key, sequence)
→ Protocol Type: Indicates the type of encapsulated payload

    - GRE Modes :

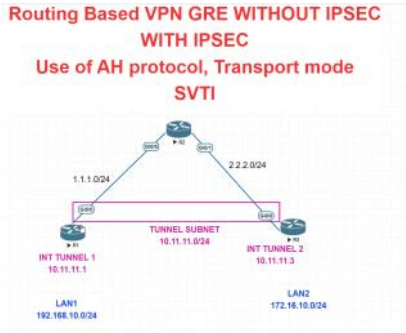
→ IP over GRE :
  - Encapsulation only the IP payload.
  - Common for simple tunneling
→ GRE over IP sec.
  - GRE provide routing flexibility
  - IPsec adds encryption and Integrity.

- GRE Advantages :
  → Supports multicast and Broadcast traffic (useful for routing protocols)
  → Compatible with many routing protocols like OSPF, EIGRP, BGP.
- Limitations :
  → Adds overhead (24 bytes)
  → No built-in security features.
- **Difference Between GRE & IP sec**

→

GRE	IPSEC
Creates virtual tunnels over IP	Secure the traffic in the tunnel
Supports multicast & dynamic routing	Encrypts and authentication packets
No built in encryption	No support for multicast on its own

- **GRE over IPsec Workflow :**
  → GRE encapsulates the original packet.
  → IP sec encrypts the entire GRE packet.
  → Encrypted GRE is transmitted over the internet.
  → Use case:
    - Two branch office need secure communication.
    - Must run OSPF or EIGRP between them.
    - Solution : Use GRE for routing support and IP sec for encryption.
  → Advantages:
    - Supports multicast and broadcast traffic.
    - Allows dynamic routing protocols
    - Offers encryption, integrity, and authentication
    - Flexible and scalable for enterprise VPN

→ 

    - After creating GRE I have 2 paths one via tunnel and one through the ISP.
    - Int Tunnel is not communicate with the private IP's, because those are Public IP's.
- **MGRE**
  → MGRE stands for Multipoint Generic Routing Encapsulation.
  → Allow a single tunnel interface to connect with multiple remote peers.
  → Ideal for hub and spoke topologies.
  → GRE Protocol Number. 47
  → Supports multicast, broadcast and dynamic routing
  → Commonly used with IPsec for encryption.
- **NHRP : (Next Hop Resolution Protocol)**
  → NHRP is a layer 2.5 protocol used in Non-Broadcast Multi-Access Networks like MGRE/DMVPN.
  → Protocol Number 54.
  → Maps tunnel IP address to real IP addresses. (Similar like ARP)
  → It's used for Dynamic peer discovery.
  → Spokes register their tunnel/public IP mapping with the Hub (NHRP server)
  → When a spoke wants to reach another spoke:
    - It sends a resolution request to the Hub.
    - Hub replies with the destination's public IP.
    - Direct tunnel is formed between the spokes
  → Key components :
    - NHRP Server : Usually the Hub
    - NHRP Clients : Spokes that register and request mappings.
  → Benefits :
    - Enables dynamic peer discovery
    - Supports spoke-to-spoke tunnels in DMVPN.
    - Reduce hub traffic after initial peer resolution.
- **DMVPN :**
  → Dynamic Multipoint VPN is a Cisco solution that combines.
    - MGRE for multipoint tunneling
    - NHRP for dynamic peer discovery.
    - IPsec for encryption.
  → Core Functionality :
    - Enables dynamic spoke-to-spoke tunnels
    - Hub acts as a control plane. Not always in the data path
    - Highly scalable for branch to branch communication.
  → How DMVPN works :
    - Spokes register with the hub via NHRP.
    - Spoke initiated traffic is sent to the hub.
    - Hub replies with real IP of the destination spoke.
    - Spokes dynamically build direct tunnels to each other.
    - IPsec encrypts the GRE payload (Transport Mode).
  → DMVPN Components :
    - MGRE
    - NHRP
    - IP sec
    - Routing Protocols (EIGRP/OSPF)
  → DMVPN Use cases
    - Enterprise WANs with many branch offices
    - Cloud connectivity to on prem networks
    - Dynamic, scalable VPNs
    - Disaster recovery links between remote locations.

- **MGRE VS DMVPN:**

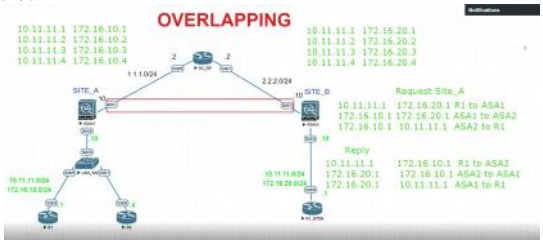
Features	MGRE	DMVPN
Tunnel Mode	Multipoint	Multipoint
NHRP	Manual	Dynamic
Peer Discovery	Manual only	Automatic via hub
Spoke to Spoke Tunnels	Not supported	On demand tunnels
Scalability	Limited	Highly scalable
Encryption	Optional	Integrated with IPsec
Configuration Efforts	High (Peer by Peer)	Low (Centralized)

  → DMVPN Hub and Spoke Topology :
    - All spokes register with the central hub.
    - Spokes can directly communicate with each other after initial discovery.
    - Hub acts as the NHRP server and control plane.
    - Reduces hub's traffic load once spoke to spoke tunnels from

- **Overlapping VPN:**
  - An overlapping VPN occurs when two or more VPN connected sites use the same internal IP address space.
  - This causes confusion in routing, NAT and security policies, as devices cannot distinguish between identical address ranges from different sites.

  > Challenges :
  - VPN gateways can't determine the correct destination
  - IP sec SA's may mismatch or reject traffic
  - Routing loops or packet drops may occur
  - **Security policies become difficult to define clearly**

  > **Scenario :**



- **GET VPN :**
  - GET VPN stands for Group Encrypted Transport VPN
  - It is Cisco technology that provides end to end encryption across private WAN's (like MPLS), without creating tunnels.
  - Key Concepts :
    - No GRE/IP sec tunnels - native IP routing is preserved
    - Encryption is applied directly to IP packet using IP sec in transport mode
    - Ideal for any to any traffic patterns
  - Core components :
    - Key Server (KS) :Central authority for distributing encryption keys and policies.
    - Group Members (GM's) : Device that encrypt/decrypt traffic using keys from the KS.
    - GDOI (Group Domain of Interpretation) : Protocol used for group key exchange (UDP 848)

- **VRF Lite :**
  - Virtual Routing and forwarding Lite is a technology that allows multiple routing table to coexist on the same router.
  - Used to segment traffic between customers, departments, or services on a single physical infrastructure.
  - Key Characteristics :
    - Logical separation without MPLS.
    - Each VRF instance maintains independent routing
    - Interface are assigned to VRFs, isolating traffic flow.
  - What is a VRF Lite aware VPN?
    → A VRF Lite Aware VPN extends VRF based segmentation across vpn tunnels
    → Allows isolated VRF instances at different sites to communicate securely over a shared network
    → How it work ?
      - VPN is bound to specific VRFs
      - Each site runs its own VRF instances and exchanges only that VRF's routes
      - VPN gateways enforce VRF to VRF mapping and encryption.

Feature	IPsec VPN	MPLS VPN
Medium	Public Internet (Unreliable).	Private Provider Backbone (Reliable)
Security	**Encrypted.** Traffic is unreadable if intercepted.	**Private, but NOT Encrypted.** Traffic is separated by labels/VRF. Ideally, you should not trust the ISP implicitly.
QoS (Quality)	Hard to guarantee. If the internet is slow, your VPN is slow.	**Guaranteed.** You can pay for SLA (Service Level Agreements) for voice/video.
Cost	Cheap (uses existing internet).	Expensive (monthly lease per link).
Ownership	You manage the devices and config.	The ISP manages the core; you just connect

- **IKE V2 :**
  → Define IKE V2 in one document rather than a combination of many.
  → Reduce setup latency reducing number of messages
  → More secure
  → Always provides identity protection (No Aggressive mode)
  → PSK is not used in crypto key generation.
  → Provide additional authentication mechanism (ESP)
  → Allow more flexible authentication choice (asymmetrical)
  → Exchange of routes and attributes
  → Reduce number of options/methods simplify implementations.
  → Reuses encapsulation model from ESP for all IKE v2 messages
  → Certificates Request are obfuscated.
  → No need for a group pre shared key
  → Suite B support Next Gen Encryption.
  → Allows for scalable AAA based PSK Lookup.
- **IKE V2 Message Exchange :**
  →
  → **Initiator** **Responder**
  | |
  | ----- **(1) IKE_SA_INIT** ------> | **(Proposals, DH Key, Nonce)**

```
|                          |
|<---- (2) IKE_SA_INIT  ------- |  (Chosen Proposal, DH Key, Nonce)
|                          |
(Encryption Keys Generated - SKEYSEED)
|                          |
|----- (3) IKE_AUTH    ------> |  (ID, Password, Traffic Rules)
|      [ENCRYPTED]          |
|                          |
|<---- (4) IKE_AUTH    ------- |  (ID, Password, Traffic Rules)
|      [ENCRYPTED]          |
|                          |
[ VPN ESTABLISHED - DATA FLOWS ]
```

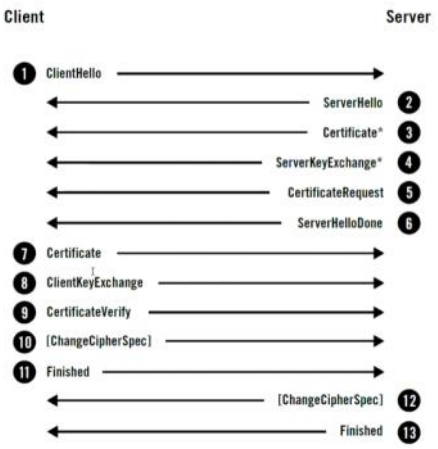
→ j

- **What is Flex VPN?**
  - Flex VPN is a unified VPN technology by Cisco that combines :
    - → Site to site VPN
    - → DM VPN
    - → Remote Access VPN
    - → Ez VPN
  - All under one configuration model using IKEv2
  - Think of it as three VPN solutions under one umbrella
  - Requirements and foundation :
    - → Requires IKEv2, which is more secure and scalable than IKEv11
    - → Minimum IOS version : 15.x
    - → Built around :
      - Virtual tunnel interfaces
      - Dynamic virtual tunnel interfaces
      - Virtual Templates
  - Flex VPN S25S Configuration Model :
    - → One site uses a virtual tunnel interface
    - → The other site uses a Dynamic Virtual Template Tunnel Interface
    - → DVTI does not require a destination IP (used in spoke sites)
    - → VTI is used on HUB sites, where the destination is known.
    - → Templates simplify tunnel creation and scale.
    - → DVTI is derived from Virtual Templates.
      - DVTI is derived from Virtual Templates.
      - DVTI allows on-demand creation of tunnels without pre-defines peers
      - Multicast support is enabled
      - Cannot assign IP addresses directly to the DVTI
        - ◆ Must use an IP from another interface.
    - → Why we are go with the Flex VPN?
      - Unified VPN configuration model.
- **IP Sec or SSL VPN differences?**

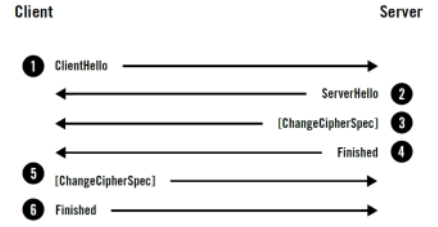
Features	**IPSec**	**SSL**
Client Software	Uses Cisco VPN client software for complete network access.	Uses a standard web browser limited corporate network resources. Eliminates need for separate client software.
Management	You must install and configure Cisco VPN client.	You do not need to install a VPN client. No configuration is required on the client machine.
Encryption	Uses a variety of encryption and hashing algorithms such as DES, 3DES, AES,SHA and MD5	Uses SSL encryption native to web browsers.
Application	Encapsulates all UP protocols, including TCP, UDP and ICMP.	Supports limited TCP based client/server applications on clientless mode. Encapsulates all IP protocols with AnyConnect client.
connectivity	Establishes seamless connection to network	Supports application connectivity through browser portal

Feature	**SSL (Deprecated)**	**TLS (Standard)**
Security	Use MAC (Message Authentication Code) with older algorithms	Uses HMAC which is much harder to crack.
Handshake	Slower. The handshake process has more steps and latency.	Faster. TLS 1.3 optimizes the handshake (1-RTT), making connections much quicker.
Alerts	Simple alert messages (often unencrypted).	Encrypted alert messages, making it harder for attackers to spy on errors.
Ports	Often required explicit port negotiation.	Works seamlessly on standard secure ports (e.g., HTTPS on 443).

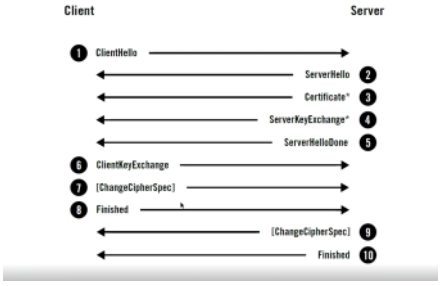
- **What is TLS?**
  - → Transport Layer Security.
  - → It is a cryptographic protocol that ensure secure communication over a computer network.
  - → TLS is the successor of SSL (Secure Sockets Layer)
  - → Used in HTTPs, email, messaging, and VoIP.
  - **Why do we need TLS?**
    - → Protect data confidentiality
    - → Ensure data integrity
    - → Provides authentication
    - → Prevents eavesdropping, MITM attacks, data manipulation.
  - Real-World usage of TLS
    - → Web Browsing
    - → Email services
    - → VPNs
    - → VoIP and Messaging
    - → API security.
  - TLS Protocols :
    - → TLS Handshake Protocol
      - It allows the client and server to authenticate each other, select an encryption algorithm and exchange a symmetric key prior to data exchange.
      - It takes 6 to 13 handshakes,
    - → **Three types of Handshake:**
      - **Full Handshake with server authentication.**



- **Abbreviated handshake that resume an earlier session**



- **Handshake with client and server authentication**



- **Clientless VPN (Browser-Based)**
  This method requires no software installation. The user simply opens a web browser (Chrome, Edge, Firefox) and logs into a secure web portal (usually HTTPS).
  - **How it works:** The VPN gateway acts as a reverse proxy. When you access an internal website through the portal, the gateway fetches the data on your behalf and rewrites the content to show it in your browser.
  - **Access Level:** Limited. You can typically only access web-based applications (intranet, webmail, wikis) and sometimes file shares or limited remote desktop sessions (RDP/SSH) via browser plugins.
  - **Protocols:** Exclusively uses SSL/TLS (Layer 7 application layer).
  - Best For:
    - Third-party contractors who need access to just one application.
    - BYOD (Bring Your Own Device) where IT cannot install software on a personal laptop.
    - Public computers (e.g., kiosks) where installing software is blocked.
- **Client-Based VPN (Client-Full / Full-Tunnel)**
  This method requires a dedicated application (the "client") installed on the user's device (e.g., Cisco AnyConnect, Global Protect, FortiClient).
  - **How it works:** The client software creates a virtual network adapter on your device. It builds a "full tunnel" to the corporate network, encapsulating all traffic (or specific traffic if split-tunneling is used) from your machine.
  - **Access Level:** Complete. Your device technically becomes part of the corporate network (Layer 3). You can access everything: VoIP phones, database clients, Windows mapped drives, command-line tools, and proprietary non-web applications.

- **OpenVPN**
  - is an open-source protocol and software widely used for its flexibility, security, and low cost. It is a "build-it-yourself" tool often used by individuals, small businesses, or commercial VPN providers (like NordVPN or ExpressVPN).
- **Cisco AnyConnect**
  - (now *Cisco Secure Client*) is a proprietary enterprise application. It is designed for large corporations that need to enforce security rules (like checking if your antivirus is on) before allowing you to connect to the office network.

- Scenario Based questions :

Topic 1: VPN (IPsec & Remote Access)

Q1. I have a Site-to-Site VPN configured. Phase 1 is UP, but Phase 2 is DOWN. What could be the problem?

This tests your troubleshooting skills and knowledge of IKE phases.

The Logic:

- **Phase 1 (IKE SA):** Authenticates the devices (Peers) to each other. If this is up, your

passwords/pre-shared keys and IP connectivity are fine.

- **Phase 2 (IPsec SA):** Negotiates the actual traffic encryption (which subnets can talk).

The Answer: "If Phase 1 is up but Phase 2 is down, the peers trust each other, but they disagree on the encryption parameters for the data. Common mismatches include:

1. **Proxy ACLs (Interesting Traffic):** One side allows 192.168.1.0/24 to 10.1.1.0/24, but the other side has a typo or a mismatching mask. They must be exact mirrors.
2. **Transform Set Mismatch:** One side wants to use AES-256/SHA, but the other side is configured for AES-128/MD5.
3. **PFS (Perfect Forward Secrecy):** One side has it enabled, the other disabled."

Q2. Explain NAT-Traversal (NAT-T) and why we need it for VPNs.

This connects your NAT knowledge with VPNs.

The Answer: "Standard IPsec (ESP protocol 50) does not have port numbers, so PAT (Port Address Translation) breaks it. A router performing PAT cannot map returning ESP packets to the correct internal client. **NAT-T** detects if a NAT device is in the path during the IKE handshake. If found, it wraps the IPsec ESP packets inside **UDP Port 4500**. Since UDP has ports, the NAT router can now track the session correctly."

-